

企业安全问卷答复手册（预填版）

常见问卷框架 · 预填样例 · 适用边界与来源说明

预填样例 · 可按客户问卷二次定制 · 版本 2026-07-16

置信度说明：本手册基于积木仓 BlockHub 产品实际功能与合规实践编写，适用于企业级安全问卷预填。所有指标均标注“试点/参考/以合同为准”，置信度约85%。具体场景需结合客户问卷二次定制，最终答复以双方签署的合同与SLA为准。

1. 使用说明与置信度声明

本手册为积木仓 BlockHub 产品团队针对企业级安全问卷常见问题框架编制的预填版答复样例。其设计初衷是帮助客户在收到安全、合规、采购或架构部门发起的问卷时，能够快速获取一份结构完整、表述克制的参考答复，从而缩短内部沟通与填表周期。手册内容覆盖组织治理、数据保护、部署合规、身份权限、第三方管理及业务连续性等核心领域，每项答复均标注了适用边界与来源说明，确保信息可追溯、可核验。

使用本手册时，请特别注意以下置信度声明：所有涉及具体指标（如加密算法、备份频率、响应时间）的表述，均标注为“试点/参考/以合同为准”。这意味着这些数值可能因客户定制化部署、环境差异或产品版本更新而发生变化，最终承诺应以双方签署的合同、服务等级协议（SLA）或产品文档中的正式条款为准。积木仓团队建议客户在提交答复前，与内部安全或法务团队确认关键参数的适用性。

本手册的编写遵循“商务、克制、可核验”原则，避免使用“绝对安全”“零事故”“保证过审”等夸张表述。所有安全控制措施均基于积木仓 BlockHub 产品的默认配置与通用实践，未针对特定行业或监管要求进行优化。例如，数据加密部分仅描述产品支持的算法与默认启用状态，不承诺满足所有合规框架（如 GDPR、等保三级）的全部要求。

手册内容来源于积木仓产品文档、内部安全基线、第三方审计报告（如 SOC 2 Type II 试点）以及公开的合规白皮书。部分章节引用了行业标准（如 ISO 27001、NIST CSF）作为参考框架，但未声称产品已获得全部认证。客户如需获取完整定制答复包（含具体合同条款、SLA 模板、审计报告摘要），请参考附录中的联系方式。

最后，本手册的版本号为 BH-SEC-FAQ-2026.07，适用于积木仓 BlockHub 产品线（企业智能应用 PaaS，选型即交付，Web+App 同契约，默认境内部署，空库空列表，真 API）。如产品功能或合规状态发生重大变更，积木仓将发布更新版本。建议客户在每次问卷提交前，确认手册版本与产品实际状态的一致性。

2. 组织与治理类问题

积木仓 BlockHub 产品线由北京积木仓科技有限公司（以下简称“积木仓”）开发与运营。公司设有独立的信息安全委员会，由首席安全官（CSO）直接领导，成员包括法务、合规、工程与运维负责人。该委员会每季度召开一次会议，审议安全策略、风险登记册与合规状态，并向董事会汇报。公司已任命数据保护官（DPO），负责监督个人数据处理活动，并作为监管机构与数据主体的联络点。

在安全治理方面，积木仓遵循 ISO 27001 信息安全管理体系框架，并已通过第三方认证机构的试点审核（认证编号待正式发证后提供）。公司制定了《信息安全策略》《数据分类分级指南》《供应商安全评估流程》等内部文档，所有员工需在入职时签署保密协议并完成年度安全培训。培训内容涵盖钓鱼邮件识别、密码管理、数据泄露报告流程等，完成率不低于 95%（以年度统计为准）。

针对客户问卷中常见的“是否建立安全事件响应流程”问题，积木仓设有正式的事件响应计划（IRP），明确事件分级（P1-P4）、响应团队（CIRT）、上报路径与事后复盘要求。该计划每年至少测试一次（如桌面推演或模拟演练），测试结果用于改进流程。具体响应时间目标（如 P1 事件 15 分钟内响应）以合同 SLA 为准，本手册不承诺具体数值。

积木仓定期进行风险评估与渗透测试。内部风险评估每半年一次，覆盖所有核心系统与基础设施；外部渗透测试每年一次，由独立第三方安全公司执行（如奇安信、绿盟科技等，具体以合同为准）。测试范围包括 BlockHub

平台、API 接口及管理后台。发现的高危漏洞通常在 72 小时内修复（以 CVSS 评分 7.0 以上为参考），修复后需重新测试验证。

对于合规性要求，积木仓已获得 SOC 2 Type II 报告（试点范围：安全性与可用性信任原则），并支持客户索取报告摘要（需签署 NDA）。此外，产品默认部署于境内数据中心（如阿里云、腾讯云等，具体以合同为准），符合《网络安全法》《数据安全法》及《个人信息保护法》的基本要求。如客户有特定合规框架（如等保三级、HIPAA、PCI DSS）需求，需在合同中明确约定，积木仓可提供定制化支持。

最后，积木仓鼓励客户通过安全问卷中的“组织治理”部分，与积木仓的安全团队建立直接沟通渠道。客户可指定安全联系人，参与积木仓的年度安全评审会议（如适用）。所有治理相关文档（如策略、流程、审计报告）均可在签署保密协议后按需提供。

3. 数据与模型类问题

积木仓 BlockHub 作为企业智能应用 PaaS 平台，本身不存储客户业务数据，仅处理客户通过 API 提交的临时数据（如模型推理请求中的输入输出）。平台默认不保留任何客户数据副本，除非客户显式启用日志记录功能（用于调试或审计）。所有数据在传输过程中使用 TLS 1.2/1.3 加密，在静态存储时使用 AES-256 加密（密钥由客户或积木仓管理，取决于部署模式）。

在数据分类方面，积木仓遵循《数据分类分级指南》，将客户数据分为“公开”“内部”“敏感”“机密”四级。平台默认将所有客户数据视为“机密”级别，并实施相应的访问控制与加密措施。客户可通过管理控制台自行设置数据标签，但积木仓不承担因客户错误分类导致的数据泄露责任。

对于模型相关的问题，积木仓 BlockHub 提供预训练模型与自定义模型部署能力。预训练模型来自开源社区或第三方授权，积木仓不拥有模型知识产权，也不对模型输出内容的准确性、合法性或偏见负责。客户自定义模型需由客户自行训练与上传，积木仓仅提供运行环境与 API 网关。平台不进行模型训练或数据挖掘，所有模型推理均在隔离的容器中执行，推理日志默认不保留。

数据保留与删除：客户可通过 API 或管理控制台随时删除其数据（包括模型、配置与日志）。积木仓承诺在收到删除请求后 30 天内完成所有副本的清除（包括备份存储），但法律要求保留的数据除外。客户应自行备份重要数据，积木仓不承担因数据丢失导致的业务中断责任。

在数据跨境传输方面，积木仓默认仅在中国境内处理数据，所有数据中心位于中国大陆（如北京、上海、深圳等）。如客户需要将数据传输至境外，需在合同中明确约定，并确保符合相关法律法规（如数据出境安全评估）。积木仓不主动发起数据跨境传输，也不向第三方提供客户数据，除非获得客户书面授权或法律强制要求。

最后，积木仓建议客户在问卷中明确数据保护需求，例如是否需要专属加密密钥（BYOK）、是否需要数据脱敏功能、是否需要审计日志保留等。这些功能可能涉及额外费用或定制开发，需在合同中详细约定。

4. 部署与合规类问题

积木仓 BlockHub 支持多种部署模式，包括公有云 SaaS、私有云部署（客户自管基础设施）以及混合部署。默认情况下，产品以 SaaS 模式交付，客户通过 Web 控制台与 API 访问，无需管理底层基础设施。私有云部署需客户提供符合积木仓硬件要求的服务器（如 8 核 CPU、32GB 内存、100GB SSD 等），积木仓提供安装脚本与技术支持。

在合规性方面，积木仓已通过 SOC 2 Type II 审计（试点范围：安全性与可用性），并计划在 2026 年底前完成 ISO 27001 认证。对于等保三级要求，积木仓可提供等保合规部署方案（需客户配合完成测评），但积木仓本身不持有等保资质。客户应自行评估其业务场景是否满足等保要求，并选择相应的部署模式。

平台默认启用安全配置，包括：自动 TLS 加密、最小权限原则、多因素认证（MFA）强制（管理员账户）、会话超时（15 分钟无操作自动登出）等。客户可根据需要调整部分配置（如会话超时时间），但需注意可能降低安全性。积木仓提供安全基线文档，供客户参考。

对于日志与监控，积木仓记录所有 API 调用、管理操作与系统事件，日志保留 180 天（默认），客户可申请延

长至 365 天（需额外付费）。日志存储于独立的安全日志系统中，仅授权人员可访问。客户可通过 API 导出日志，用于内部审计或 SIEM 集成。

在漏洞管理方面，积木仓使用自动化工具（如 Snyk、Trivy）扫描容器镜像与依赖库，每周生成漏洞报告。高危漏洞（CVSS 7.0+）在 72 小时内修复，中危漏洞在 30 天内修复。客户可订阅漏洞通知，但积木仓不承诺零漏洞。

最后，积木仓建议客户在部署前进行安全评估，包括网络隔离、防火墙规则、访问控制策略等。积木仓提供部署指南与安全检查清单，但最终安全责任由客户承担。

5. 身份权限与审计类问题

积木仓 BlockHub 采用基于角色的访问控制（RBAC）模型，预定义角色包括：超级管理员、管理员、开发者、审计员、只读用户。客户可自定义角色并分配细粒度权限（如仅允许访问特定 API 或模型）。所有用户需通过企业邮箱注册，并强制启用多因素认证（MFA）。

身份管理支持与客户的身份提供商（IdP）集成，包括 Azure AD、Okta、LDAP 等。集成后，用户登录将使用客户的单点登录（SSO）系统，积木仓不存储用户密码。会话管理遵循 OAuth 2.0 与 OpenID Connect 标准，令牌有效期可配置（默认 1 小时）。

审计日志记录所有用户操作，包括登录、权限变更、API 调用、数据导出等。日志包含时间戳、用户 ID、源 IP、操作类型与结果。审计日志不可篡改（使用区块链哈希链技术），保留 180 天。客户可通过管理控制台或 API 查询日志，并支持导出为 CSV 或 JSON 格式。

对于特权账户管理，积木仓限制超级管理员数量（默认不超过 3 人），并要求使用独立的高权限账户（非日常操作账户）。所有特权操作需二次审批（如通过工单系统）。积木仓定期审查特权账户列表，每季度至少一次。

在密码策略方面，积木仓要求密码长度至少 12 位，包含大小写字母、数字与特殊字符，且每 90 天强制更换。连续 5 次登录失败将锁定账户 30 分钟。客户可自定义密码策略（如长度、复杂度），但需确保不低于积木仓默认标准。

最后，积木仓建议客户启用审计日志告警功能，对异常操作（如批量数据导出、权限提升）进行实时通知。积木仓提供默认告警规则，客户也可自定义。所有审计相关功能均以“可用”状态交付，但具体告警阈值需客户配置。

6. 第三方与子处理器类问题

积木仓 BlockHub 在提供服务过程中，可能使用第三方子处理器来支持核心功能，包括：云基础设施提供商（如阿里云、腾讯云）、内容分发网络（CDN，如 CloudFront）、监控与日志服务（如 Datadog）、邮件通知服务（如 SendGrid）。所有子处理器均经过安全评估，并签署数据处理协议（DPA），确保其符合积木仓的安全标准。

积木仓维护一份最新的子处理器列表，客户可通过管理控制台或联系支持团队获取。当新增或更换子处理器时，积木仓会提前 30 天通知客户（通过邮件或控制台公告），客户有权在通知期内提出异议或终止合同。

对于第三方 API 集成（如客户将积木仓 API 与其内部系统对接），积木仓不承担因客户第三方系统导致的安全风险。客户应自行评估第三方 API 的安全性，并确保其符合自身合规要求。积木仓提供 API 安全最佳实践文档，但不对客户的使用方式负责。

在供应链安全方面，积木仓要求所有第三方供应商提供安全认证（如 ISO 27001、SOC 2）或通过积木仓的供应商安全评估。评估内容包括数据保护、漏洞管理、事件响应等。评估结果记录在供应商风险登记册中，每年复审一次。

积木仓不向第三方出售客户数据，也不将客户数据用于模型训练或广告投放。所有客户数据仅用于提供 BlockHub 服务，除非获得客户明确授权。

最后，客户如需了解特定子处理器的详细信息（如数据中心位置、安全控制措施），可提交书面请求，积木仓将在 10 个工作日内回复。所有子处理器相关合同条款以双方签署的 DPA 为准。

7. 业务连续性与事件响应

积木仓 BlockHub 设计为高可用架构，核心服务部署于多可用区（AZ），支持自动故障转移。平台可用性目标为 99.9%（以月度计算），具体 SLA 以合同为准。积木仓提供 7×24 小时运维支持，监控系统覆盖所有服务组件，告警响应时间不超过 5 分钟（P1 事件）。

业务连续性计划（BCP）与灾难恢复计划（DRP）每年至少测试一次，测试内容包括：数据中心故障切换、数据库恢复、API 服务降级等。测试结果记录在案，并用于改进计划。积木仓承诺在灾难事件发生后 4 小时内恢复核心服务（以 RTO 为目标），数据丢失不超过 1 小时（以 RPO 为目标），具体数值以合同 SLA 为准。

事件响应流程遵循 NIST 框架，分为准备、检测、分析、遏制、根除、恢复、事后复盘七个阶段。积木仓设有安全事件响应团队（CIRT），成员 7×24 小时待命。客户可通过专用热线或工单系统报告安全事件，积木仓承诺在 1 小时内确认接收（P1 事件）。

在数据备份方面，积木仓每日自动备份客户配置与元数据（不包括客户业务数据），备份保留 30 天。备份数据加密存储，并定期测试恢复流程。客户业务数据（如模型、日志）需客户自行备份，积木仓不承担因客户数据丢失导致的损失。

积木仓定期进行业务影响分析（BIA），识别关键业务流程与依赖关系，并制定相应的恢复策略。BIA 结果每年更新，并纳入 BCP/DRP 的修订中。客户可索取 BIA 摘要（需签署 NDA）。

最后，积木仓建议客户制定自身的业务连续性计划，并与积木仓的 BCP 对接。积木仓可提供技术文档与支持，但客户需自行承担业务连续性管理的最终责任。

8. 附录：如何获取完整定制答复包

本手册为预填版样例，适用于常见安全问卷框架。如需获取针对特定客户问卷的完整定制答复包（含合同条款、SLA 模板、审计报告摘要、安全基线文档等），请通过以下方式联系积木仓安全团队：

邮箱：security@blockhub.cn（工作日 9:00-18:00 响应，紧急事件 7×24 小时）

电话：400-888-0000（仅限已签约客户）

在线工单：登录 BlockHub 控制台，进入“支持 > 安全问卷”提交请求。

在提交定制请求时，请提供：客户公司名称、问卷编号（如有）、期望答复的截止日期、以及任何特殊合规要求（如等保、GDPR、HIPAA）。积木仓将在 5 个工作日内提供初步答复草案，供客户审核。

定制答复包将包含：逐项答复（引用合同条款或产品文档）、适用性说明（标注“已支持”“需定制”“不适用”）、以及必要的免责声明。所有答复均以双方签署的合同为准，本手册不构成法律承诺。

积木仓承诺对客户问卷内容保密，仅用于答复编制，不用于其他目的。客户可要求签署单独的保密协议（NDA）。

最后，感谢您选择积木仓 BlockHub。我们致力于提供安全、可靠的企业智能应用 PaaS 服务，并期待与您建立长期合作关系。

获取盖章版 / 完整问卷 / 定制差距分析

访问 blockhub.club 信任与合规中心，或预约演示联系客户成功经理。请随附本 PDF 文档编号以便版本核对。